

Best practice по списочным методам

Про списочные методы

[Списочные методы](#) предназначены для получения по установленным параметрам набора записей. Для решения большинства задач, например при работе с любыми [видами списков](#), подходит [Декларативный списочный метод](#). Он предоставляет возможность в упрощенной форме конфигурировать набор полей в возвращаемых записях, добавлять дополнительные рассчитываемые поля, сортировать результаты выборки, а также рассчитывать данные для [строки итогов](#). Но данный тип списочного метода использует устаревший вид навигации, поэтому от него стоит отказаться в пользу списочного метода [Реализуемого вручную](#).

Описание проблемы

Для обоих типов методов основной проблемой является отсутствие ограничений (на стороне бизнес логики) на количество получаемых данных от БД, что может приводить к атакам типа "отказ в обслуживании".

Примеры небезопасных списочных методов

Ниже приведены примеры небезопасных вызовов списочных методов с клиента, которые могут привести к атакам типа "отказ в обслуживании"

1. Метод не имеет никаких ограничений по лимиту при вызове без навигации.

Ниже приведен пример ручной реализации списочного метода в котором проверяется лимит, но только в случае, если передана навигация. Если навигация не задана, то проверка не работает.

```
# декоратор ограничивающий максимальную навигацию для списочных методов не BuildList
def list_limitation(func):
    def wrapper(fields, filter, sorting, navigation):
        if navigation:
            if navigation.Type() == sbis.NavigationType.ntPOSITION:
                limit = navigation.Limit()
            elif navigation.Type() == sbis.NavigationType.ntPAGE:
                limit = navigation.RecsOnPage()
            else:
                limit = MAX_NAVIGATION_LIST_PAGE_SIZE
                Если аргумент navigation не задан, то мы сюда не попадем
            if limit > MAX_NAVIGATION_LIST_PAGE_SIZE:
                raise sbis.Warning(("Данный списочный метод нельзя вызывать с навигацией больше {}. "
                                   + "Используйте наборный метод BuildList(Full) и укажите в Доп поля колонки "
                                   + "которые вам необходимы").format(MAX_NAVIGATION_LIST_PAGE_SIZE))
        return func(fields, filter, sorting, navigation)
    return wrapper
```

2. Метод с [постраничной навигацией](#), т.к использует не оптимальный режим работы с источником данных списка.

Ниже приведен вызов декларативного списочного метода с лимитом навигации от 0-30, который использует постраничную навигацию:

Хоть навигация и передается, но запрос в БД сначала отберет все записи удовлетворяющие фильтру, а после обрежет их по указанному лимиту.

Поэтому лимит в данном случае не обеспечивает уменьшение нагрузки на БД.

Последствия эксплуатации

Повышенная нагрузка на базу данных, что может привести к отказу в обслуживании и простою сервиса. Доступ к конфиденциальной информации.

Как исправить?

Так как списочные методы имеют различные типы реализации и могут быть вызваны с клиента, как с параметрами, так и без. К ним сложно применить общие требования. Поэтому одной из мер борьбы от повышенной нагрузки на БД был ввод ограничения на количество запрашиваемых записей. Но данное ограничение не распространяется на вызовы списочных методов без навигации.

Ограничение на количество запрашиваемых записей

Ограничение распространяется только на вызовы с клиента и не затрагивает [межсервисное взаимодействие](#).

Ограничение настраивается в сервисе ["Управление облаком"](#) в параметре **"Ядро.Сервер приложений.МаксимальныйРазмерВыборкиСписочныхМетодов"**.

На данный момент максимальный размер выборки 10000 записей.

Дополнительно

Так как выше указанное ограничение не применяется при вызове метода без навигации. Предлагаются следующие рекомендации по разработке и вызову новых списочных методов.

Рекомендации к разработке и вызову списочных методов

1. При вызове без навигации метод не возвращает все, что есть в базе. А реализует одно из следующих действий:
 - о выдает ошибку
 - о выдает предупреждение и возвращает 0 записей

- о запрашивает и возвращает количество записей в зависимости от своего внутреннего лимита (желательно не более 100)

2. Использовать навигацию [по курсору](#)

3. Со стороны клиента желательно всегда вызывать метод с навигацией и лимитом не более 100